

Cybersecurity by Design for Critical Infrastructures

Laurea Magistrale in Informatica

`alma.pennacchi@uniroma2.it`

Marzo 2026



TOR VERGATA
UNIVERSITÀ DEGLI STUDI DI ROMA

1 From Observability to Decision

Domanda guida

Una volta osservata e modellata un'infrastruttura, come decidiamo che un comportamento sia **normale**, **anomalo**, **malevolo** o **non ancora classificabile**?

- definire la **normalità** in un sistema complesso
- misurare **deviazioni** in presenza di incertezza
- distinguere **anomalia**, **guasto**, **attacco**, **drift**

Osservazione → Rappresentazione → Baseline → Deviazione → Decisione

Punto chiave

Il problema non è solo *vedere* un evento. Il problema è decidere se quell'evento sia compatibile con il comportamento atteso del sistema.

Definizione

Data una infrastruttura definita come un insieme di nodi di elaborazione di informazioni in grado di ricevere e trasmettere Ad ogni nodo, ad un certo istante di tempo, è associato uno stato. Un comportamento è l'insieme delle variazioni di stato dell'infrastruttura in un determinato intervallo di tempo e dei relativi flussi informativi verificatosi fra ogni possibile coppia di nodi.

- Chiusura transitiva di un grafo pesato in nodi e archi dove i pesi cambiano ad ogni istante di tempo. Lo chiamiamo Configurazione.

La normalità non è un punto

Idea

In una infrastruttura critica la normalità non coincide con un singolo valore, ma con una **regione di comportamenti ammessi**.

- il traffico notturno non coincide con quello diurno
- una finestra di manutenzione cambia i pattern ammessi
- un'emergenza clinica può alterare volumi e sequenze

Operating Envelope

Definition (Operating Envelope)

Insieme delle condizioni operative compatibili con il comportamento atteso del sistema.

- range di volumi
- latenze ammissibili
- sequenze consentite
- relazioni topologiche attese

Conseguenza

Un evento non è anomalo perché “diverso dalla media”, ma perché **esce dall'inviluppo operativo ammesso**.

Baseline come insieme ammissibile

Sia $\mathcal{X}$ l'insieme di tutte le configurazioni osservabili che può assumere una infrastruttura (lo spazio dei comportamenti osservabili).

Baseline

$$B = \{x \in \mathcal{X} : x \text{ è compatibile con il comportamento atteso}\}$$

Allora:

$$x \notin B \Rightarrow \text{deviazione}$$

Attenzione

Nella pratica B non è noto esattamente: viene **stimato** da dati, regole, vincoli operativi e contesto.

La baseline non è una sola.

- **temporale**: quando avvengono gli eventi
- **topologica**: chi comunica con chi
- **volumetrica**: quanto traffico passa
- **frequenziale**: con che periodicità
- **sequenziale**: in quale ordine avvengono le azioni
- **di stato**: quali transizioni sono consentite

Baseline temporale

- backup notturni
- login concentrati in certe fasce orarie
- sincronizzazioni periodiche
- traffico ridotto nei weekend

Esempio

Un picco alle 03:00 può essere perfettamente normale se coincide con una procedura schedulata.

- HMI → PLC
- SCADA → Historian
- VPN → Gateway
- DMZ → OT tramite conduit definito

Esempio

Se compare una comunicazione PLC → Internet, la deviazione è topologica prima ancora che volumetrica.

Baseline sequenziale

Non conta solo *cosa* avviene, ma *in quale ordine*.

- autenticazione → autorizzazione → accesso
- lettura stato → comando → conferma
- update → restart → sync

Idea

Due eventi leciti, in sequenza sbagliata, possono costituire una deviazione.

Un'infrastruttura evolve tra stati.

idle → active → maintenance → recovery

- alcune transizioni sono attese
- altre sono rare
- altre ancora non dovrebbero mai avvenire

Interpretazione

L'anomalia può essere una **transizione di stato illegittima**.

Definizione

La deviazione è la misura della distanza tra il comportamento osservato e la regione di comportamento atteso.

$d(x, B) \rightarrow$ score di deviazione

- score basso: variazione compatibile
- score intermedio: comportamento da indagare
- score alto: probabile rottura della baseline